

Access Control Policy

NCA ECC | AI Rajhi Technologies

Prepared for:	AI Rajhi Technologies
Industry:	Banking and Financial Services
Prepared by:	kayShahbaaz
Date:	27 August 2026
Classification:	CONFIDENTIAL

1. Purpose and Scope

This Access Control Policy applies to all employees, contractors, consultants, and third-party service providers of AI Rajhi Technologies who access the organization's information assets. It covers all information systems, networks, applications, and data classified as confidential, restricted, or higher, including banking transaction processing platforms and customer financial records. The policy does not apply to publicly available marketing websites that do not process or store customer data.

2. Policy Statement

- 2.1 All user accounts must be uniquely identified and assigned to a single individual, and shared or generic accounts must be prohibited for production banking systems.
- 2.2 Access rights to information assets must be granted based on the principle of least privilege and must be approved by the data owner prior to account creation.
- 2.3 Role-based access controls must be implemented for all critical banking applications, and each role must be documented in the access control matrix.
- 2.4 Privileged access, including administrative and root privileges, must be restricted to authorized personnel and must require multi-factor authentication.
- 2.5 Access to customer financial data must be logged, and logs must be retained for a minimum of twelve months in accordance with NCA ECC and SAMA CSF requirements.
- 2.6 All access control changes, including additions, modifications, and deletions, must be recorded in the change management system and must be reviewed by the IT Security Manager within five business days.
- 2.7 User accounts must be disabled immediately upon termination of employment or contract, and the disabling action must be verified by the HR department and the CISO.
- 2.8 Periodic access reviews must be conducted at least quarterly for all privileged accounts and must be documented with corrective actions taken for any discrepancies.
- 2.9 Remote access to AI Rajhi Technologies' internal networks must be secured using VPN technology that enforces strong encryption and must require multi-factor authentication.
- 2.10 All default passwords supplied by vendors must be changed before system deployment, and default accounts must be disabled or removed.
- 2.11 Access to systems handling payment card data must comply with PCI DSS requirements and must be subject to additional monitoring as mandated by the NCA.
- 2.12 Any request for elevated access must be submitted through the formal access request workflow and must include a risk assessment signed by the requesting department manager.
- 2.13 The IT Security Manager must conduct an annual audit of access control mechanisms and must report findings to the CISO and the Board's Risk Committee.
- 2.14 All staff must complete the annual security awareness training that includes modules on access control policies and must acknowledge understanding of this policy.

- 2.15 Exceptions to this policy may be granted only by the CISO with documented justification and must be reviewed by the compliance office within thirty days.
- 2.16 The organization must implement automated account provisioning and de?provisioning tools that enforce the defined access control rules.
- 2.17 Access to development and test environments must be segregated from production environments, and data must be anonymized or masked where feasible.
- 2.18 Any suspected violation of this policy must be reported immediately to the Incident Response Team, and the incident must be investigated in accordance with the Incident Management Procedure.
- 2.19 All third?party service providers must sign a contractual agreement that includes adherence to AI Rajhi Technologies' access control requirements and must undergo a security assessment annually.
- 2.20 The CISO must ensure that the access control policy is aligned with the latest NCA ECC revisions and must update the policy within thirty days of any regulatory change.

3. Roles and Responsibilities

The Chief Information Security Officer (CISO) is responsible for approving access control exceptions, overseeing policy compliance, and reporting to senior management. The IT Security Manager is responsible for implementing technical controls, conducting access reviews, and maintaining audit logs. Department Managers must ensure that access requests from their staff are justified, approved, and aligned with the principle of least privilege. All staff members must adhere to the access control procedures, protect their credentials, and report any suspected misuse.

4. Review and Maintenance

The Access Control Policy shall be reviewed at least annually to ensure continued relevance and effectiveness. An out?of?cycle review shall be triggered by significant regulatory updates, major security incidents, or changes to the organization's information systems architecture.

5. Compliance and Exceptions

All personnel within scope of this policy must comply with its requirements. Exceptions must be approved in writing by the CISO or equivalent.

6. Document Approval

Role	Name	Signature	Date
Policy Owner			
CISO / Security Lead			
Executive Sponsor			